

Cirque Corporation

Secure Development Procedure

Document ID: IS-CIRQ-PR-017-G

Category: IT Security Related

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the systematic process for integrating information security into the software development lifecycle (SDLC), including the development of firmware and ASIC designs. This procedure aims to minimize vulnerabilities, ensure the confidentiality, integrity, and availability of developed systems and intellectual property (IP), and comply with IS-CIRQ-P-012-G: Secure System Acquisition, Development and Maintenance Policy and ISO/IEC 27001:2022 Annex A.8.25.

****2. Scope****

2. Scope

This procedure applies to all Cirque personnel (employees, contractors) involved in the design, development, coding, and integration of software, firmware, and hardware designs (e.g., ASIC designs). This includes internal development using tools like ****GitLab**** and ****Cadence****, as well as customization or integration of third-party

applications.

****3. Responsibilities****

3. Responsibilities

- ****Development Managers/Leads:**** Responsible for ensuring their teams adhere to this procedure and secure coding practices.
- ****Developers/Engineers:**** Responsible for implementing secure coding, design, and testing practices as defined herein.
- ****IT Manager/Security Personnel:**** Responsible for providing security guidance, tools, and reviewing security vulnerabilities during development.

****4. Procedure****

4. Procedure

****4.1. Secure Development Environment**** a. ****Separation:**** Development, testing, and production environments shall be logically and, where technically feasible, physically separated. Access between environments shall be strictly controlled. b. ****Access Control:**** Access to development environments, including source code repositories (e.g., ****GitLab****), design tools (e.g., ****Cadence****), and associated data, shall be restricted to authorized personnel on a need-to-know basis. c. ****Workstation Hardening:**** Development workstations shall be securely configured and regularly patched, equipped with anti-malware software (****Windows Defender for Business****), and protected by encryption where applicable (e.g., Full Disk Encryption via ****Intune****). d. ****Production Data:**** Use of actual production data in development or test environments is strictly prohibited unless it has been adequately anonymized, pseudonymized, or sanitized to remove sensitive information.

****4.2. Secure Design and Requirements**** a. ****Security Requirements**

Gathering:** For every new system or significant feature, information security requirements shall be defined at the design phase. This includes: * Identification of sensitive data processed or stored. * Required authentication and authorization mechanisms. * Input validation and output encoding needs. * Error handling strategies. * Resilience and availability considerations. * Protection of intellectual property (e.g., ASIC/firmware design integrity). b.

Threat Modeling: Threat modeling or security design reviews shall be conducted for critical systems to identify potential vulnerabilities early in the design phase.

4.3. Secure Coding Practices (Software and Firmware) a. **Coding Standards:** Developers shall adhere to secure coding guidelines and best practices relevant to the programming language and platform being used (e.g., OWASP Top 10 for web applications, MISRA C/C++ for firmware). b. **Input Validation:** All user input and data from untrusted sources shall be rigorously validated to prevent injection attacks (e.g., SQL injection, command injection) and buffer overflows. c. **Error Handling:** Applications shall handle errors gracefully without revealing sensitive information or internal system details. d. **Secure Configuration:** Code shall be designed to operate with secure default configurations and minimize reliance on insecure settings. e. **Logging:** Relevant security events and application errors shall be logged appropriately as per IS-CIRQ-PR-015-G: Logging and Monitoring Procedure.

4.4. Secure Development Practices (ASIC/Hardware Design via Cadence) a. **IP Protection:** Rigorous access controls and versioning shall be applied to all **Cadence** design files and related IP in **GitLab**. b. **Secure Design Principles:** Security considerations (e.g., side-channel attack resistance, secure boot, tamper detection) shall be

incorporated into the ASIC design process where applicable. c.

****Verification:**** Design verification methodologies shall include checks for security vulnerabilities at the hardware level.

****4.5. Version Control and Code Management (GitLab)**** a. All source code, firmware, and design files (e.g., ****Cadence**** files) shall be managed in ****GitLab**** using appropriate version control practices. b.

****Branching Strategy:**** A secure branching strategy shall be enforced (e.g., protected branches for master/main, requiring pull requests and code reviews for merges). c. ****Access Control:**** Access to ****GitLab**** repositories shall be managed on a need-to-know basis, with granular permissions. d. ****Commit Hygiene:**** Developers shall be encouraged to write clear and concise commit messages, avoiding sensitive information.

****4.6. Code Review and Peer Review**** a. All code (software, firmware, and significant hardware design changes) shall undergo peer review or formal code review before being merged into main branches or deployed. b. Code reviews shall include a focus on identifying security vulnerabilities, adherence to coding standards, and correct implementation of security requirements.

****4.7. Use of Third-Party Components and Libraries**** a. ****Vulnerability Scanning:**** Where applicable, third-party libraries and open-source components used in development shall be scanned for known vulnerabilities. b. ****Licensing:**** Ensure compliance with licensing requirements for all external components. c. ****Updates:**** Components shall be regularly updated to address security vulnerabilities.

****4.8. Static Application Security Testing (SAST)**** a. SAST tools shall be integrated into the development pipeline (e.g., in ****GitLab CI/CD****) to automatically scan source code for common vulnerabilities. b. Identified issues shall be addressed and remediated by developers

according to severity.

****5. Review and Update****

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirquel's development tools (e.g., ****GitLab****, ****Cadence****), methodologies, or emerging security threats in software/hardware development.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-012-G: Secure System Acquisition, Development and Maintenance Policy
- IS-CIRQ-PR-013-G: Change Management Procedure
- IS-CIRQ-PR-018-G: System Testing and Acceptance Procedure (To be drafted next)
- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-P-008-G: Access Control Policy
- IS-CIRQ-PR-015-G: Logging and Monitoring Procedure